

MODULO 2

***PRÁCTICA N6 ->**

“Evasión de Firewall”

- 1. Fragmentación de paquetes (Packet Fragmentation)

Esta técnica divide los paquetes TCP en trozos más pequeños para que los filtros de inspección del firewall no reconozcan la firma del escaneo.

Comando:

sudo nmap -f 31.214.178.4

Explicación: La bandera -f fragmenta los paquetes. Si el firewall no tiene la capacidad de reensamblar paquetes antes de analizarlos, el escaneo pasará de largo.

```
(kali㉿kali)-[~]  
$ sudo nmap -f 31.214.178.4  
[sudo] contraseña para kali:  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 20:13 +0100  
Nmap scan report for hostingsrv18.dondominio.com (31.214.178.4)  
Host is up (0.0061s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
53/tcp    open  domain  
80/tcp    open  http  
443/tcp   open  https  
  
Nmap done: 1 IP address (1 host up) scanned in 5.09 seconds
```

2. Uso de Señuelos (Decoys)

Hacemos que el firewall vea múltiples ataques desde diferentes IPs, ocultando nuestra IP real entre la multitud.

Comando:

sudo nmap -D RND:10 31.214.178.4

Explicación: -D RND:10 genera 10 direcciones IP aleatorias (señuelos) que parecen estar escaneando la web al mismo tiempo que tú. El administrador del sistema verá 11 IPs atacando y no sabrá cuál es la tuya.

```
(kali@kali)-[~]  
$ sudo nmap -D RND:10 31.214.178.4  
[sudo] contraseña para kali:  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 20:13 +0100  
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 3.10 seconds
```

3. Escaneo Sigiloso (TCP SYN Stealth Scan)

Es el escaneo por defecto de Nmap pero es el más efectivo para evadir registros de

aplicación porque nunca completa la conexión TCP.

Comando:

```
sudo nmap -sS -Pn 31.214.178.4
```

Explicación:

-sS: Envía un paquete SYN y espera la respuesta, pero no envía el último ACK, dejando la conexión "a medias".

-Pn: Salta la comprobación de si el host está vivo (ping), muy útil si el firewall bloquea paquetes ICMP.

```
(kali@kali)-[~]  
$ sudo nmap -sS -Pn 31.214.178.4  
[sudo] contraseña para kali:  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 20:14 +0100  
Nmap scan report for 31.214.178.4  
Host is up.  
All 1000 scanned ports on 31.214.178.4 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap done: 1 IP address (1 host up) scanned in 205.78 seconds
```

4. Escaneo Lento y Discreto (Timing Templates)

Para evadir firewalls modernos que bloquean IPs si detectan demasiadas conexiones en poco tiempo.

Comando:

sudo nmap -T1 31.214.178.4

Explicación: -T1 (Sneaky) hace que Nmap espere mucho tiempo entre el envío de cada paquete. Es extremadamente lento pero muy difícil de detectar por sistemas de prevención de intrusos (IPS).

```
(kali@kali)-[~]  
$ sudo nmap -T1 31.214.178.4  
[sudo] contraseña para kali:  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 20:14 +0100  
RTTVAR has grown to over 2.3 seconds, decreasing to 2.0  
█
```

5. Manipulación de MTU y Puertos de Origen

Engañamos al firewall enviando paquetes desde puertos que suelen estar permitidos (como el de DNS o el de una web).

Comando:

```
sudo nmap --source-port 53 --mtu 24  
31.214.178.4
```

Explicación:

--source-port 53: Hace que parezca que el tráfico viene de un servidor DNS legítimo.

--mtu 24: Ajusta el tamaño máximo de transmisión a 24 bytes para forzar al firewall a procesar paquetes inusualmente pequeños.

```
(kali㉿kali)-[~]  
$ sudo nmap --source-port 53 --mtu 24 31.214.178.4  
[sudo] contraseña para kali:  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 20:14 +0100  
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 3.07 seconds
```